CAREFLOW AI

Platform Overview, Operations & Technical Policy Handbook

Product Name: CAREFLOW AI

Architecture Baseline: Architecture v3

Product Category: AI-Powered Clinic Operations & Patient Management SaaS

Document Scope: LangChain RAG Knowledge Base Reference

1. Platform Overview & Business Model

CAREFLOW AI is an AI-powered Clinic Operations and Patient Management Platform delivered as a web-based Software-as-a-Service (SaaS) application. The platform centralizes daily healthcare clinic administration, patient management, appointment scheduling, clinical consultations, e-prescriptions, billing, subscriptions, staff coordination, and AI-assisted clinical and operational workflows.

Under the CAREFLOW AI SaaS business model, clinic owners are the paying subscribers, and patients are customers of the enrolled clinics. Subscription plans are structured around clinic configuration, single-clinic or multi-clinic operations under one owner, and AI assistant entitlements.

- Simplify daily clinic administration and front-desk queue operations.
- Streamline appointment booking, check-in, and patient medical history tracking.
- Support doctors and clinical staff with structured encounter notes, vitals, and e-prescriptions.
- Enforce strict multi-tenant clinic data isolation and role-based access control (RBAC).
- Provide metered, safety-guarded AI assistance for clinical and administrative workflows.

2. Technical Architecture & Infrastructure Stack

CAREFLOW AI is built on a full-stack TypeScript architecture combining server-side rendering, strict relational database isolation, and Google Gemini AI services. Firebase is strictly prohibited across all modules.

Layer / Domain	Technology & Implementation Details
Frontend Framework	React 19 with TanStack Start (full-stack SSR/SSG), Vite 8 bundler, Nitro server runtime (`cloudflare-module` preset), and TypeScript 5.8 (`strict: true` , `exactOptionalPropertyTypes: true`).
Routing & State	TanStack Router file-based nested layouts (`_authenticated/{admin,clinic,doctor,staff,patient}.tsx`) and TanStack React Query v5 paired with authenticated server RPC functions (`createServerFn`).
UI & Styling	shadcn/ui (New York style, slate palette), Radix UI primitives, Tailwind CSS v4, Lucide React icons, React Hook Form with Zod validation, Motion for React, Recharts, and Sonner notifications.

Layer / Domain	Technology & Implementation Details
Backend & Database	Supabase PostgreSQL 15+ database, Supabase Auth, Row Level Security (RLS), private Supabase Storage buckets, and security-definer database stored procedures.
AI & Vector Engine	Google Gemini (`@google/genai`) using `gemini-3.8-flash` , `gemini-3.7-flash` , and `gemini-embedding-001` (3072-dimension embeddings) with PostgreSQL HNSW vector indexes.
Payments & Mail	Live Razorpay subscription checkout with HMAC SHA-256 webhook verification, and multi-tenant Google Gmail OAuth 2.0 mailbox integration encrypted with AES-256-GCM.
Hosting & CI/CD	GitHub source control (`main` and `testing-branch`) connected to Vercel for preview and production deployments, validated with Vitest and ESLint.

3. User Roles & Workspace Access Policy (RBAC)

CAREFLOW AI enforces a five-role architecture. Authorization is resolved strictly server-side from user profile records (`profiles`) and clinic membership tables (`clinic_members`) via `requireSupabaseAuth` and database helper functions (`private.has_clinic_role`). Frontend navigation visibility is strictly presentational and never treated as an authorization boundary.

User Role	Workspace Route	Authorized Capabilities & Scope
Platform Super Admin	`/_authenticated/admin.*`	Manages SaaS platform governance, clinic directories, verification approvals/rejections, clinic suspensions/revocations, tenant subscriptions, user account statuses, platform analytics, and unmetered governance AI queries.
Clinic Owner	`/_authenticated/clinic.*`	Manages single or multiple clinics, onboarding, license verification, 6-month reverification, doctor and staff rosters, patient records, appointments, queue supervision, billing ledgers, subscription plans, Gmail OAuth, and metered AI tools.
Doctor	`/_authenticated/doctor.*`	Conducts clinical consultations, records longitudinal vitals, writes clinical assessments, issues e-prescriptions, reviews patient medical timelines, and uses the metered clinical AI assistant under human-in-the-loop rules.
Staff	`/_authenticated/staff.*`	Manages front-desk patient check-in, live patient waiting queues, appointment scheduling, and invoice payment collection.
Patient	`/_authenticated/patient.*` and `/register`	Books appointments online, views upcoming consultations, accesses active and past prescriptions, downloads official PDF billing receipts, views personal medical history, and completes QR/kiosk self-registration.

4. Clinic Onboarding & Verification Policy

Every clinic enrolled on CAREFLOW AI must complete structured onboarding and compliance verification before accessing operational features.

- **Required Onboarding Details:** Clinic Display Name, auto-generated clinic code, clinic type, postal code, geographic latitude and longitude, official registration number, representative name, representative phone number, and mandatory compliance documents.
- **Private Document Storage:** Verification files are stored in a private Supabase Storage bucket named `clinic-verification` with folder-level isolation (`{clinic_id}/{document_type}`) governed by PostgreSQL storage RLS policies.
- **Operational Access Gate:** Clinics in pending, suspended, or revoked states are restricted from operational dashboards until `clinic_is_operational` evaluates to true. Clinic owners cannot modify their own verification status.
- **Six-Month Reverification Rule:** Approved clinics must submit updated compliance documents every six months. An automated hourly background job (`private.run_reverification_maintenance` via `pg_cron`) monitors deadlines, issues notifications, and suspends clinics that fail to complete reverification on time.

5. Subscription Plans & Billing Policy

CAREFLOW AI operates on a recurring subscription model integrated with live Razorpay payment processing and server-side webhook verification.

- **Available Plan Tiers:** Single Clinic AI, Single Clinic without AI, Multi-Clinic AI, Multi-Clinic without AI, and Max AI.
- **Trial Mandate Enrollment:** Supports 21-day trial enrollments authorized via Razorpay mandates (`subscription.authenticated` event triggering `confirm_trial_mandate`).
- **Webhook Security & Deduplication:** Incoming Razorpay webhooks at `/api/public/razorpay-webhook.ts` verify HMAC SHA-256 signatures using `RAZORPAY_WEBHOOK_SECRET` and deduplicate events via the `razorpay_webhook_events` primary key.
- **Single Active Subscription Rule:** Verified plan activations automatically supersede and cancel prior active plans so a clinic never holds duplicate active subscriptions.
- **Atomic Invoice Settlement:** Patient and clinic invoice payments are recorded through the atomic stored procedure `record_invoice_payment` using optimistic concurrency control (OCC) to prevent double-payments.

6. AI Engine, Credit Quotas & Metering Policy

CAREFLOW AI provides Google Gemini AI capabilities governed by server-side subscription plan entitlements and atomic credit metering.

Subscription Plan	Monthly AI Credit Limit	Quota & Sharing Policy
Single Clinic AI	500 credits / month	Dedicated monthly credit pool for a single enrolled clinic; resets on subscription billing date.
Multi-Clinic AI	1,500 credits / month	Shared monthly credit pool across all clinics managed under the subscribing clinic owner.
Max AI	2,000 credits / month	Higher monthly quota; applies an intentional 8-second response throttle after reaching the monthly threshold rather than immediately blocking access.
Plans without AI	0 credits / month	AI assistant features remain disabled (`clinic_ai_enabled` evaluates to false).

- **Credit Charging Rule:** Exactly one credit is charged per successful AI request, and balances reset on the subscription billing date.
- **Atomic Reservation & Settlement:** Before invoking Gemini, the server reserves a credit via `ai_reserve_credit_as` using an idempotent `requestId`. Upon completion, usage is settled via `ai_finish_credit_as`.
- **Zero-Cost Failure Refund:** If an AI request fails or encounters an upstream error, settlement is recorded with `p_success: false` and no credit is deducted from the clinic quota.
- **Platform Super Admin Exemption:** Platform Super Admins execute governance RAG queries unmetered without consuming clinic AI credits.

7. RAG Knowledge Base & Vector Search Architecture

Retrieval-Augmented Generation (RAG) in CAREFLOW AI uses a dedicated, restricted PostgreSQL `rag` schema with direct public access revoked. Vector embeddings are generated using Google Gemini `gemini-embedding-001` at 3072 dimensions and indexed with PostgreSQL HNSW cosine similarity indexes (`halfvec(3072)`).

Knowledge Domain	Storage Table & RPC	Access Control & Isolation Rules
CONFIDENTIAL	`rag.confidential_chunks` via `rag_search_confidential`	Stores platform governance, verification policies, subscription rules, and audit guidelines. Restricted exclusively to active `PLATFORM_ADMIN` accounts; contains zero Protected Health Information (PHI).
CLINIC	`rag.clinic_chunks` via `rag_search_clinic`	Stores clinic-specific Standard Operating Procedures (SOPs) and internal documents. Enforces strict `clinic_id` multi-tenant isolation and retrieves only documents with `APPROVED` status.

Knowledge Domain	Storage Table & RPC	Access Control & Isolation Rules
SHAREABLE	`rag.shared_chunks` via `rag_search_shared`	Stores general medical and clinical reference guidelines accessible across verified clinics and platform administrators.

8. Clinical AI Safety & Human-in-the-Loop (HITL) Policy

Clinical AI assistance in the Doctor Workspace (`doctorPatientRagSearch`) combines static `CLINIC` and `SHAREABLE` vector search with real-time patient clinical records—including recent consultations, longitudinal vitals trends, and active or historical prescriptions.

- **Strict Cross-Tenant Isolation:** Before retrieving clinical records or reserving AI credits, the server verifies that the requesting user is an active `DOCTOR` or `OWNER` member of the target clinic and that the target `patient_id` belongs strictly to that `clinic_id` .
- **Human-in-the-Loop (HITL) Drafting Only:** The Doctor AI Assistant operates strictly in drafting mode. AI outputs cannot directly insert, update, or overwrite clinical notes, vitals, or e-prescriptions in the database.
- **Explicit Doctor Confirmation:** Doctors must review AI-generated clinical summaries or prescription presets and manually trigger confirmation actions before saving records through standard clinical procedures (`save_consultation`).

9. Communications & Gmail OAuth 2.0 Policy

CAREFLOW AI enables clinics to send official operational communications directly from their own verified clinic email address rather than generic third-party mailers.

- **OAuth 2.0 Mailbox Authorization:** Clinic owners authorize their Google Workspace or Gmail account through a multi-tenant OAuth 2.0 flow stored in `clinic_gmail_connections` .
- **AES-256-GCM Token Encryption:** OAuth refresh tokens are encrypted at rest using AES-256-GCM authenticated encryption (storing ciphertext, initialization vector, and authentication tag).
- **Direct MIME Delivery:** Doctor and staff team invitations as well as patient portal activation links are formatted as MIME multipart messages and dispatched directly through the clinic's authorized mailbox.

10. Security, Privacy & Healthcare Data Protection Policy

Because CAREFLOW AI manages sensitive clinical and patient records, all application modules enforce ten mandatory data protection principles: least privilege, clinic-level multi-tenant isolation, role-based authorization, server-side validation, secure authentication, private file storage, full auditability, atomic data integrity, zero secret exposure, and minimal PHI collection.

- Row Level Security (RLS) must never be disabled on any database table.
- Service-role keys, Razorpay secrets, Gemini API keys, and Gmail encryption keys must remain strictly server-side and never be exposed in client bundles.
- Patients can access only their own authorized appointments, prescriptions, medical history, and invoices, and can never view another patient's records.
- All verification decisions, administrative clinic actions, and patient demographic updates are recorded in immutable audit trails (`audit_logs` and `verification_events`).

11. Source Control, Branching & Deployment Policy

CAREFLOW AI follows a controlled multi-branch GitHub workflow integrated with Vercel automated deployments.

- **`main` Branch:** Production-ready codebase deployed to live production on Vercel. Direct pushes to `main` are prohibited.
- **`testing-branch`:** Integration and pre-production validation branch used for feature verification prior to production release.
- **Feature Branches:** All new features and fixes (such as `Phase-2`) are developed in isolated branches created from `testing-branch`, validated with TypeScript checks (`npx tsc --noEmit`), unit/integration tests (`npx vitest run`), and production build checks (`npm run build`), and submitted via Pull Request targeting `testing-branch` for Project Owner review.

12. LangChain RAG Ingestion Note & Disclaimer

This handbook is structured with numbered sections, concise paragraphs, explicit role and quota tables, and standardized technical terminology to support reliable document loading, recursive text chunking, vector embedding, and grounded question-answering in LangChain chatbot applications.

> **Disclaimer:** This document is a structured product and technical reference handbook compiled exclusively from CAREFLOW AI's approved specifications and codebase architecture for LangChain RAG chatbot development and knowledge retrieval.